

Termin 8 – Technische Resilienz II

Zero Trust, Microsegmentation, Cloud Resilience und Network Design

Prof. Dr. Dirk Loomans

29. September 2026

Vorlesungsskript • Grundlagen der Resilienz • Cyber Security Management (B.Sc.), 1. Semester • Hochschule Mainz

Vorbemerkung: Dieses Skript dient als Vorlesungsbegleitung und erhebt keinen akademischen Anspruch. Dennoch kann es bei der Klausurvorbereitung hilfreich sein. Kommentare und Verbesserungsvorschläge gerne an den Autor über dirk.loomans@hs-mainz.de.

Leitfrage

Wie begrenzt Architektur den Schaden, wenn Prävention versagt?

Von Wiederherstellung zu Widerstandsfähigkeit: Resilienz ist mehr als Backups.

Lernziele

Nach diesem Termin können Studierende

- Zero Trust verstehen und anwenden,
- erklären, wie laterale Bewegung verhindert wird,
- Cloud-Strukturen resilient gestalten,
- Netzarchitektur als Resilienzinstrument nutzen,
- das Zusammenspiel der vier Ansätze begründen und priorisieren.

Fachinhalte

Kontext: kontrollierte Verwundbarkeit

Cloud, mobile Arbeit, vernetzte Lieferketten, IoT-Produktion und Software-defined Infrastructure vergrößern Angriffs- und Fehlerflächen. Das Ziel verschiebt sich von „Schutz um jeden Preis,“ zu **kontrollierter Verwundbarkeit**: Systeme bleiben trotz erfolgreicher Kompromittierung widerstandsfähig. Vier Architekturbausteine prägen moderne Resilienzstrategien:

- **Zero Trust** – Vertrauen wird nicht vorausgesetzt, sondern dynamisch überprüft.
- **Microsegmentation** – logische Aufteilung in isolierte Sicherheitszonen.
- **Cloud Resilience** – hochverfügbare, ausfallsichere Architekturen in skalierbaren Umgebungen.
- **Network Design** – Kommunikationswege ohne Single Points of Failure.

Zero Trust

Vom Perimeter zum Kontext. Das klassische Burgmodell setzt implizites Vertrauen innerhalb des Perimeters voraus. Cloud, Homeoffice, BYOD, VPN-Zugänge, SaaS- und API-Ökosysteme lösen diesen Perimeter auf. Angreifer scheitern nicht mehr an der Firewall, sondern bewegen sich mit gestohlenen

Zugangsdaten unbemerkt lateral. Nicht der Angriff selbst, sondern seine unbemerkte Ausbreitung wird zum größten Risiko.

Definition: Zero Trust verweigert implizites Vertrauen und verlangt für jeden Zugriff – unabhängig von Herkunft, Identität oder Standort – eine explizite, kontextabhängige und kontinuierliche Autorisierung [1]. Leitsätze: „Never trust – always verify“, Identität statt Netzwerkstandort, Assume Breach.

Leitprinzipien:

1. **Assume Breach** – Angreifer sind bereits im System oder morgen darin; Fokus auf Schadensbegrenzung.
2. **Least Privilege Access** – minimal, granular, zeitlich begrenzt (Admin-Zugriff nur für die Dauer einer Wartung).
3. **Strong Identity & Authentication** – MFA, Hardware-Token, passwortlose Verfahren.
4. **Continuous Authorization** – Zugriffe werden bei Risikosignalen, Standort- oder Gerätewechsel neu geprüft.
5. **Device & Workload Trust** – auch Endgeräte, Server, IoT und Container werden bewertet (Patchstand, Integrität, Zertifikate).
6. **Visibility, Telemetry & Policy Enforcement** – ohne Daten keine Resilienz.

Bausteine: IAM, PAM, Network Access Control, Endpoint Security und Device Posture, Policy Decision und Enforcement Points, Microsegmentation, Telemetrie/SIEM.

Warum Zero Trust resilient macht: begrenzt die Angriffsfläche, verhindert Eskalation, reduziert Kompromittierungsfolgen, unterstützt schnelle Recovery. **Zero Trust reduziert nicht die Wahrscheinlichkeit eines Angriffs, sondern die maximale Schadenswirkung.**

Typische Fehler: „Zero Trust ist ein Produkt,“; organisatorische Widerstände (Admins verlieren Vollzugriffe, Fachbereiche müssen Zugriffe begründen); Legacy- und OT-Systeme ohne moderne Authentisierung; Über-Optimismus („verhindert Angriffe“); zu großer Projektscope; fehlende Erfolgsmessung (etwa Reduktion überprivilegierter Konten, kürzere Incident-Response-Dauer). Zero Trust ist ein Weg, kein Zielzustand.

Microsegmentation

Definition: feingranulare, softwarebasierte Unterteilung in isolierte Sicherheitsbereiche bis auf Workload-, Endpunkt- oder Datenflussebene – nicht nur VLANs oder Firewall-Zonen, sondern Software-defined statt physisch. **Je größer die interne Bewegungsfreiheit, desto größer der potenzielle Gesamtschaden.**

Warum Microsegmentation? Sie stoppt laterale Bewegung, schafft klare Kommunikationspfade, hält Angriffe lokal, vereinfacht Forensik und operationalisiert Need-to-Know für ISO 27001, DSGVO, KRITIS und PCI-DSS.

Ansatz	Umsetzung	Stärken	Schwächen
netzwerkbasiert	L3/L4-Firewalls, SDN, virtuelle Switches, ACLs	etablierte Technik, klare Zuständigkeit	IP/Port-Regeln unflexibel, hoher Pflegeaufwand
host-/workloadbasiert	Host-Firewalls, Agenten, eBPF, Cloud-native Controls	unabhängig von der Topologie, sehr feingranular	Agent-Management, Performance-Risiken

Ansatz	Umsetzung	Stärken	Schwächen
identitäts-/ applikationsbasiert	Service Accounts, Workload-Zertifikate, OIDC, SPIFFE/SPIRE	dynamisch, cloud- und containerfreundlich	braucht ausgereiftes IAM

Policy-Design: Die wichtigste Frage ist nicht „Wer darf rein?“, sondern „Wer muss wirklich miteinander kommunizieren?“ – Allow-List statt Block-List („deny all“), Application Dependency Mapping, kontextbasierte Regeln, zuerst Audit-Modus, dann Enforcement.

Typische Fehler: alles auf einmal segmentieren; Start ohne Datenflussanalyse; Segmentierung ohne Verantwortliche für Ausnahmen, Pflege und Überwachung; Verständnis als reine Security- statt Resilienzmaßnahme. „Technologie segmentiert Systeme – aber nur Organisationen segmentieren Risiko.“

Cloud Resilience

Cloud Resilience ist die Fähigkeit cloudbasierter Systeme, trotz Störungen, Angriffen und Fehlkonfigurationen funktionsfähig zu bleiben oder sich schnell zu erholen. **Die Cloud ist nicht automatisch resilient – sie ermöglicht Resilienz, wenn man sie bewusst gestaltet.**

Shared Responsibility Model: Der Anbieter sichert physische Infrastruktur, Hardware, Rechenzentren und Netz. Beim Kunden bleiben Datenintegrität, IAM-Konfiguration, Backup-Strategie, Zugriffskontrollen, Logging, Segmentierung, Compliance und Datenklassifizierung. Cloud-Anbieter ≠ Datensicherung.

Architekturprinzipien:

1. Multi-AZ- und Multi-Region-Design
2. zustandslose, entkoppelte Anwendungen (Container, Serverless)
3. Load Balancing und Auto-Scaling
4. Immutable Infrastructure: ersetzen statt reparieren (IaC, Golden Images, GitOps)
5. Backups trotz Cloud: Off-Cloud-Kopie, regionenübergreifende Sicherung, Restore-Tests
6. resilientes IAM: phishing-resistente MFA, Just-in-Time-Privilegien, Schlüsselrotation
7. Observability und Chaos Engineering
8. optional Multi-Cloud oder Souveränitätsstrategien

„Cloud-Resilienz kommt aus Design – nicht aus einem Anbieterlogo.“

Fehlannahmen: „Der Anbieter kümmert sich um alles,“; blindes Vertrauen in eingebaute Redundanz (oft nur innerhalb einer Zone); fehlende Exit-Strategie und Vendor Lock-in; Automatisierung verbreitet Fehler schneller; fehlende eigene Telemetrie; überdimensionierte Multi-Cloud-Strategien; mangelnde IAM-Hygiene. **Cloud-Resilienz ohne Test ist hypothetische Resilienz.**

Network Resilience

Netzwerke sind die Grundlage aller anderen Resilienzmaßnahmen: Ohne Netz sind Backups nicht abrufbar, kann Zero Trust keine Identitäten prüfen und sind Cloud-Workloads nicht erreichbar. Risiken: BGP-Manipulation, DDoS, fehlerhafte Firmware- oder Konfigurationsupdates, Glasfaserschäden, Switch-Ausfälle, SPOFs in WAN- und MPLS-Verbindungen.

Architekturprinzipien: Redundanz statt Zentralisierung – und zwar diversifiziert (zwei Carrier, zwei Stromphasen); Eliminierung von SPOFs; resiliente Topologien; getrennte Management-, Produktions- und Benutzerzonen; DNS-, Routing- und Identity-Resilienz; Telemetrie; Automatisierung gegen Konfigurationsdrift.

Resiliente Design Patterns: Leaf-Spine statt klassischer Stern (symmetrische Pfade, vorhersehbare Latenz); SD-WAN zur Dezentralisierung mit dynamischem Failover; redundante Pfade und Carrier-

Unabhängigkeit. DNS, Routing und IAM sind kritisch – in der Praxis scheitern Systeme häufiger an DNS oder IAM als an Hardware.

Fehlannahmen: „Es läuft seit Jahren, also ist es stabil,“ – Stabilität ohne Störung beweist nur Glück. Redundanz ohne Unabhängigkeit (zwei Leitungen vom selben Provider, zwei Firewalls im selben Rack). Veraltete Netzdokumentation. Keine DDoS-Strategie. Zu starke Abhängigkeit von MPLS oder VPN. „Ein Netzwerk ist nicht resilient, weil es funktioniert – sondern weil es auch dann funktioniert, wenn etwas ausfällt.“

Zusammenspiel

Ansatz	Primärer Fokus	Resilienzbeitrag
Zero Trust	Identitäten und Zugriffsentscheidungen	Schadensbegrenzung, kein implizites Vertrauen
Microsegmentation	interne Bewegungsfreiheit	Bewegungskontrolle, begrenzt Ausbreitung
Cloud Resilience	Workload- und Datenverfügbarkeit	skalierbare Wiederherstellung
Network Resilience	Transport und Kommunikation	stabile Grundlage, Erreichbarkeit

Die Ansätze kompensieren gegenseitig blinde Flecken: Zero Trust begrenzt das Risiko kompromittierter Credentials, Microsegmentation begrenzt deren Folgen; Cloud Resilience erleichtert den Wiederanlauf, Network Resilience stellt die Pfade bereit. **Resilienz entsteht nicht aus Technologie, sondern aus Interoperabilität.**

Empfohlene Reihenfolge: (1) Netzwerkstabilität schaffen, (2) Identitätssysteme stärken, (3) Microsegmentation vorbereiten, (4) Cloud-Resilienz gestalten, (5) Zero Trust operationalisieren. So wird Resilienz aufgebaut, nicht eingekauft.

Übungsblatt: GameNova GmbH

Die GameNova GmbH betreibt eine Multiplayer-Gaming-Plattform hybrid: Authentifizierung und Nutzerprofile in der Public Cloud (AWS), Matchmaking-Server im eigenen Rechenzentrum, Spieldatenbank als Managed-SQL-Cloud-Service, Web-Frontend über ein globales CDN, Adminzugriff über klassisches VPN.

Vergangene Vorfälle: gestohlene Admin-Credentials mit unbemerktem Login; Ransomware in einem Entwicklernetzsegment; zweistündiger Plattformausschlag durch einen Routerdefekt; offen konfigurierter Storage-Bucket mit Telemetriedaten. Die Geschäftsführung fordert ein „Resilienzprogramm,“.

Aufgabe	Punkte
1 Zero Trust – a) drei konkrete Prinzipien für das Szenario; b) welche Strukturen sich ändern müssen; c) realistischer erster Implementierungsschritt	20
2 Microsegmentation – a) zwei zwingend zu trennende Bereiche mit Begründung; b) Risiken ohne Trennung; c) benötigte Informationen vor der Regeldefinition	20

Aufgabe	Punkte
3 Cloud Resilience – a) drei Architekturmaßnahmen; b) warum Cloud-Datenreplikation kein Backup ersetzt; c) Backup-Strategie mit Standort, Häufigkeit und Testverfahren	25
4 Network Resilience – a) wahrscheinlichster SPOF; b) zwei Netzwerkdesignmaßnahmen; c) wie die Wirksamkeit geprüft wird	20
5 Integration & Priorisierung – a) Umsetzungsreihenfolge der vier Maßnahmen; b) Begründung nach Risiko, Aufwand und Wirkung	15

Bearbeitungszeit 60–90 Minuten; Folien, Skript und Online-Recherche erlaubt; Stichpunkte genügen, müssen aber begründet sein; keine technischen Detailkonfigurationen erforderlich.

Prüfungsrelevante Leitfragen

Zero Trust: Unterschied zwischen Perimeter-Sicherheit und Zero Trust? Warum ist „Assume Breach“, zentral? Welche Rolle spielt IAM? Drei Mechanismen kontinuierlicher Autorisierung? Warum ist Zero Trust keine Produktentscheidung?

Microsegmentation: Definition und Abgrenzung zur klassischen Segmentierung? Sicherheitsgewinn gegen laterale Bewegung? Netzwerk-, host- und identitätsbasierte Umsetzung? Warum ist eine Datenflussanalyse zwingend? Warum scheitert Microsegmentation ohne Governance?

Cloud Resilience: Was ist das Shared Responsibility Model, und welche Missverständnisse entstehen? Drei Architekturprinzipien? Warum ersetzt Cloud-Datenredundanz kein Backup? Risiken hoher Automatisierung? Rolle der Observability?

Network Resilience: Warum ist Network Resilience die Grundlage aller anderen Maßnahmen? Drei typische SPOFs? Was unterscheidet Redundanz von echter Resilienz? Vorteile von Leaf-Spine? Warum sind DNS und Routing häufiger Ausfallursache als Hardware?

Integration und Transfer: Wie ergänzen sich Zero Trust und Microsegmentation im Angriffsszenario? Warum kann eine Organisation mit guter Cloud-Resilienz operativ ausfallen? Welche Implementierungsreihenfolge ist sinnvoll? „Multi-Cloud erhöht automatisch Resilienz“, – stimmen Sie zu?

Zusammenfassung: Resilienz ist Architektur, nicht Backup. Vertrauen wird nicht vorausgesetzt. Angriffswege werden begrenzt. Architektur entscheidet über Krisenfähigkeit.

Vor- und Nachbereitung

Ausblick Termin 9: Sonderthemen – OT-Resilienz mit Gastvortrag aus der Praxis und KI-Resilienz.

Material aus dem Archiv

08 Technische Resilienz II/08_Technische Resilienz II.pdf, 08 Skript Technische Resilienz.pdf und 08 Übungsblatt.pdf.

Bibliografie

- [1] S. Rose, O. Borchert, S. Mitchell, und S. Connelly, „Zero Trust Architecture“, NIST Special Publication 800-207, Aug. 2020. doi: [10.6028/NIST.SP.800-207](https://doi.org/10.6028/NIST.SP.800-207).